

Guide Anti-Phishing pour Associations

Reconnaître, éviter et réagir face aux tentatives d'hameçonnage — Biscuits IA 2026

Qu'est-ce que le phishing ?

Le phishing (hameçonnage) est une technique de cyberattaque où des fraudeurs se font passer pour une entité de confiance (banque, administration, plateforme connue) afin de voler des informations sensibles : identifiants, coordonnées bancaires, données personnelles.

Les associations sont des cibles de choix car elles gèrent des données de bénéficiaires, des financements publics et ont souvent des équipes bénévoles moins formées à la cybersécurité.

1. Reconnaître un e-mail de phishing

- L'adresse expéditeur ne correspond pas au domaine officiel (ex: contact@impots-remboursement.com)
- Ton urgent ou menaçant : "Votre compte sera suspendu dans 24h"
- Fautes d'orthographe ou de grammaire inhabituelles
- Lien hypertexte qui pointe vers un domaine différent du texte affiché
- Pièce jointe inattendue (.zip, .exe, .docm, .xlsm)
- Demande d'informations personnelles ou financières par e-mail
- Logo ou charte graphique légèrement différente de l'original

& Vérifiez TOUJOURS l'URL en survolant le lien avant de cliquer. Ne faites pas confiance au nom affiché.

2. Les types d'attaques les plus courants en 2026

- Phishing classique — faux e-mail d'une administration ou banque
- Spear phishing — e-mail ciblé avec votre nom, poste ou contexte réel
- Smishing — SMS frauduleux (ex: faux avis de livraison, fausse amende)
- Vishing — appel téléphonique imitant votre banque ou la police
- QR Code phishing — QR code dans un flyer ou e-mail renvoyant vers un faux site
- Fausses plateformes de subventions — copie de France Relance, FONJEP...

3. Checklist de réaction immédiate

- ☐ Ne pas cliquer sur les liens, ne pas ouvrir les pièces jointes
- ☐ Signaler l'e-mail via le bouton "Signaler comme phishing" de votre messagerie
- ☐ Transférer l'e-mail à phishing@cyber.gouv.fr (ANSSI)
- ☐ Si vous avez cliqué : changer immédiatement le mot de passe du compte concerné
- ☐ Si données bancaires saisies : appeler votre banque en urgence et bloquer la carte
- ☐ Signaler sur signal-spam.fr ou phishing-initiative.eu
- ☐ Prévenir le reste de l'équipe pour éviter qu'ils ne tombent dans le même piège

4. Bonnes pratiques préventives

- ☐ Former tous les membres à reconnaître un phishing (session 30 min/an minimum)
- ☐ Activer la double authentification sur toutes les boîtes mail professionnelles
- ☐ Utiliser un filtre anti-spam professionnel (ex: Mailinblack, Vade Secure)
- ☐

Activer DMARC, DKIM et SPF sur votre domaine de messagerie

- ☐ Tester vos équipes avec des simulations de phishing (GoPhish, KnowBe4)
- ☐ Tenir un registre des incidents de sécurité, même mineurs

Ressource officielle : cybermalveillance.gouv.fr — Assistance gratuite aux particuliers et associations victimes de cybercriminalité.

5. Configuration technique recommandée

- SPF : enregistrement DNS qui liste les serveurs autorisés à envoyer en votre nom
- DKIM : signature cryptographique ajoutée à chaque e-mail sortant
- DMARC : politique déclarant ce que les destinataires doivent faire en cas d'échec SPF/DKIM
- HTTPS obligatoire sur votre site (certificat SSL Let's Encrypt = gratuit)
- Filtre de contenu sur les navigateurs des postes de travail

